CASE STUDY

SolarWinds and SUNBURST: The Supply-Chain Intrusion, 2019 to 2021

A TeamStarWolf case study. Published 3 November 2026; every source checked as of that date.

Executive summary

For most of 2020, thousands of IT teams installed a routine, digitally signed update to SolarWinds Orion, the network monitoring platform that sits on some of the most trusted servers in an enterprise. The update carried a backdoor. Nobody at SolarWinds had written it into the source code: a small implant on the company's build server, later named SUNSPOT, watched for the compiler to start, swapped one source file for a trojanized copy for the length of the build, and put the original back (Confirmed [7][9]). The resulting DLL was signed by SolarWinds' own certificate and shipped through SolarWinds' own update channel (Confirmed [6]). Fewer than 18,000 customers may have installed an affected version (Confirmed [14]); the attackers then picked a small fraction of them for hands-on follow-up, which the White House later put at nine federal agencies and about 100 private companies (Confirmed [53]).

The story is often told as a single event in December 2020. The record is longer and messier. The SEC alleged the attackers were inside SolarWinds' VPN by January 2019 (Confirmed as an allegation [40]; the case was later dismissed [43]); SolarWinds dates the earliest suspicious activity it found to September 2019 and a quiet test run to October 2019 (Confirmed [9]); the backdoor went into builds on 20 February 2020 and was pulled out in June 2020 (Confirmed [9][13]). FireEye found the intrusion while investigating its own compromise, which it disclosed on 8 December 2020 together with the theft of its red-team tools (Confirmed [45][47][48]), and published SUNBURST on 13 December (Confirmed [6]). The most damaging phase for many victims was not the Orion foothold but what came after it: theft of AD FS token-signing certificates, forged SAML tokens and new credentials on cloud applications, which let the operators read mail in Microsoft 365 with forged tokens and added application credentials (Confirmed [12][22][23]).

In April 2021 the United States and the United Kingdom attributed the operation to Russia's Foreign Intelligence Service, the SVR (Confirmed [54][56]). The actor did not go away: through 2021 the same group, tracked by Microsoft as NOBELIUM and now Midnight Blizzard, ran mass phishing from USAID's account on the Constant Contact email marketing service, planted FoggyWeb on AD FS servers and turned to cloud resellers and service providers as the next trusted channel (Confirmed [61][64][65]). The policy consequences were large and lasting: Emergency Directive 21-01, Executive Order 14028, the NTIA SBOM minimum elements, the NIST Secure Software Development Framework and the OMB attestation memo all follow from this incident (Confirmed [25][59][97][87][98]; Inferred for the lineage, and Log4j later shaped the SBOM argument).

Key facts at a glance

Item	Detail	Grade
What happened	A build-system compromise that inserted the SUNBURST backdoor into signed SolarWinds Orion updates, followed by selective hands-on intrusion and cloud identity abuse	Confirmed [6][7][9]
Earliest access	January 2019 VPN access alleged by the SEC; GAO states SolarWinds was breached as early as January 2019; September 2019 per SolarWinds; ATT&CK lists the campaign as first seen August 2019	Confirmed [40][44][9][1]
Build implant	SUNSPOT, binary build timestamp 20 Feb 2020; SUNBURST inserted into builds from that day	Confirmed [7][9]
Affected releases	Orion Platform 2019.4 HF 5, 2020.2 with no hotfix, 2020.2 HF 1, released March to June 2020	Confirmed [17][14]
Signed backdoor	SolarWinds.Orion.Core.BusinessLayer.dll, signed 24 Mar 2020	Confirmed [6]
Installed by	Fewer than 18,000 customers, of about 33,000 active-maintenance Orion customers notified	Confirmed [14]
Compromised by follow-on activity	Nine federal agencies and about 100 private-sector companies	Confirmed [53]
Discovery	FireEye red-team tool theft disclosed 8 Dec 2020; SolarWinds notified 12 Dec; SUNBURST published 13 Dec	Confirmed [47][19][6]
Federal order	CISA Emergency Directive 21-01, 13 Dec 2020: disconnect or power down affected Orion; sunset 8 Jan 2026	Confirmed [25]
Attribution	United States and United Kingdom: the SVR, 15 Apr 2021; ATT&CK maps campaign C0024 to G0016 APT29	Confirmed [54][56][1]
CVE	None for SUNBURST; CVE-2020-10148 belongs to the separate SUPERNOVA web shell story	Inferred for SUNBURST; Confirmed for CVE-2020-10148 [32][33][79]
ATT&CK objects	Campaign C0024; group G0016; software S0559 SUNBURST, S0562 SUNSPOT, S0560 TEARDROP, S0565 Raindrop	Confirmed [1][2][3][4][5]
Policy outcome	Executive Order 14028, signed 12 May 2021	Confirmed [59][60]
Legal outcome	SEC v. SolarWinds and its CISO filed 30 Oct 2023; dismissed with prejudice by joint stipulation, 20 Nov 2025	Confirmed [41][43]

Key findings

- **The build, not the source, was the target.** SUNSPOT replaced InventoryManager.cs only while MsBuild.exe was compiling Orion and restored it afterwards, checking hashes first so the build would not fail (Confirmed [7]). Kevin Mandia told the Senate that the build process, not the source code, was modified (Confirmed [45]). Code signing worked exactly as designed and so signed the backdoor (Confirmed [6]; Inferred for the lesson).

- **The operators rehearsed.** An October 2019 Orion release carried test modifications that Microsoft describes as empty classes (Confirmed [9][20]); SolarWinds' timeline graphic shows a trial run from 12 September to 4 November 2019 (Confirmed [13]).
- **SUNBURST was built to stay quiet.** It slept for about two weeks, ran only on domain-joined hosts, checked blocklists of security tools, and dressed its traffic as the Orion Improvement Program protocol (Confirmed [6][21]).
- **Most installs were never used.** Fewer than 18,000 customers may have installed the update (Confirmed [14]); follow-on compromise reached nine federal agencies and about 100 companies (Confirmed [53]). The SEC complaint put the number hit by secondary attacks at about 100 of 18,000 (Confirmed as an allegation [40]).
- **The worst harm ran through identity.** Stolen AD FS signing keys, Golden SAML tokens, changed federation trusts and new service-principal credentials gave quiet access to cloud mail (Confirmed [12][22][23]). The technique had been public since 2017 (Demonstrated [92]; Confirmed [45]).
- **Not every victim came through Orion.** CISA listed password guessing and spraying and external remote services as other initial vectors (Confirmed [12]); Volexity's think-tank case included an Exchange exploit and a Duo MFA bypass before the Orion breach (Confirmed [10]).
- **Attribution was slow and careful, then firm.** In the four months to April 2021 the vendor reports cited here used cluster names and named no country (Confirmed [6][10][69][7]); Kaspersky's Kazuar overlap was offered as a lead, not an attribution (Confirmed [70]); the government moved from "likely Russian in origin" in January 2021 to a high-confidence SVR attribution in April (Confirmed [52][54]).
- **The actor kept working.** NOBELIUM's 2021 campaigns used a marketing-mail platform, AD FS backdoors and the delegated admin rights of cloud resellers (Confirmed [61][64][66]).

Top recommendations

1. **Treat the build system as production.** Isolate build hosts, make build resources ephemeral, and compare independent reproducible builds so a compile-time source swap shows up as a mismatch (Confirmed [85][87]; Inferred that this would have exposed SUNSPOT).
2. **Restrict and log the egress of management servers.** SUNBURST beaconed over DNS to avsvmcloud[.]com subdomains (Confirmed [6][12]); that this was the first observable, and that retained passive DNS made retro-hunting possible, is this study's inference (Inferred).
3. **Protect the identity provider as a tier-zero asset.** Hunt for "impossible tokens", AD FS configuration changes and added service-principal credentials; roll the token-signing certificate twice and reset krbtgt twice after compromise (Confirmed [12][24][91]).
4. **Plan for rebuild, not cleanup.** CISA judged a full rebuild the safest action for environments with this level of access (Confirmed [12]).
5. **Ask suppliers for provenance.** Use SSDF attestation, SBOMs in NTIA formats and integrity verification as procurement levers, while recognizing that a self-attestation is not an audit (Confirmed [87][97][98][86]; Inferred for the caution).

Scope and method

This study covers the SolarWinds Orion supply-chain compromise and the activity ATT&CK groups under campaign C0024 (August 2019 to January 2021), with the 2021 NOBELIUM campaigns that Microsoft and Mandiant tie to the same actor, the government response through 2021 and the legal record through November 2025. It draws on SolarWinds' own blog posts, security advisory and SEC filings; the primary technical reports of Mandiant (then FireEye), CrowdStrike, Microsoft, Symantec, Volexity, Palo Alto Networks Unit 42 and Kaspersky; CISA advisories and directives, White House, Treasury, UK NCSC, FCDO and NATO statements; congressional hearing transcripts; GAO and SEC records; NIST, NTIA and OMB policy documents; and the live MITRE ATT&CK, CAPEC and D3FEND records with the library's own data files. Every source was opened on 3 November 2026. Quotations are kept to a few words.

The topic is broader than any one study. This study is the home for the SolarWinds and SUNBURST record; studies of 2020 and 2021 activity summarize it and link here. The Cyber Safety Review Board's first review, which went to Log4j instead of SolarWinds, is summarized in Part 4; for Log4j itself see the library's separate Log4Shell case study.

Grade	Meaning
Confirmed	A primary source was opened: the victim company, the vendor that observed the activity, a government agency, a court or SEC record, a hearing transcript, or the MITRE record itself
Reported	Known only through a secondary source, such as press coverage or a reproduction of a document whose original was not opened
Demonstrated	A public reproduction or tool exists
Inferred	This study's own reasoning from the cited facts, labelled where it appears

Two rules matter for this incident. First, SEC complaint statements are allegations: the opened complaint is the primary record of what the SEC alleged, so the allegation is graded Confirmed as an allegation, and the dismissal is reported alongside it. Second, attribution language is carried through as each source wrote it: "nation-state", "likely Russian in origin", "highly likely" and "high confidence" are different claims, and the study keeps them apart.

Part 1: the technical record

The build-server implant: SUNSPOT

SUNSPOT is a build-process implant that called itself taskhostw.exe; its binary carries a build timestamp of 20 February 2020 11:40:02, consistent with SolarWinds' timeline (Confirmed [7]). It polled the process list every second for MsBuild.exe. When Orion was being compiled, it replaced the source file InventoryManager.cs with the SUNBURST-bearing version, and after the build it restored the original (Confirmed [7]). Before the swap it checked MD5 hashes of the target file so that a mismatched file would not break the build; CrowdStrike assessed that the operators took care to avoid build failures that might alert developers (Confirmed [7]). SUNSPOT used mutexes to ensure one instance ran, AES-encrypted blobs for its payload, a boot-time scheduled task for persistence, and an RC4-encrypted error log at C:\Windows\Temp\vmware-vmdmp.log, named to pass as a VMware file (Confirmed [7]).

SolarWinds states the updated injection source began inserting SUNBURST into builds on 20 February 2020 (Confirmed [9]). SolarWinds' CEO, Sudhakar Ramakrishna, testified that there was no evidence the TeamCity build server was the initial vector, though the possibility was not eliminated (Confirmed [45]).

The backdoor: SUNBURST

The trojanized file was SolarWinds.Orion.Core.BusinessLayer.dll, signed by SolarWinds on 24 March 2020 (Confirmed [6]). Microsoft describes the malicious OrionImprovementBusinessLayer class and SUNBURST's obfuscation: compressed, encoded and hashed strings so that the names of the things it looked for never appeared in plain text (Confirmed [20]; Inferred for the purpose). Behavior after install, from Mandiant's reports (Confirmed [6][21]):

- **Dormancy.** It waited roughly 12 to 14 days before its first beacon (ATT&CK maps this to T1497.003 Time Based Checks [2]).
- **Guardrails.** It proceeded only on domain-joined hosts and ran checks before activating (Confirmed [6]).
- **Anti-analysis.** It checked blocklists of processes, services and drivers belonging to security tools, could disable services by setting their registry Start value to 4, and read the MachineGuid registry value (Confirmed [21]).
- **DNS command and control.** It resolved DGA-generated subdomains of avsvmcloud[.]com, specific to each victim; CNAME answers handed selected victims off to HTTP command and control, and certain A-record ranges made it stop (Confirmed [6][21]).
- **Camouflage.** Its HTTP traffic imitated the Orion Improvement Program protocol and its commands were hidden in XML-like responses (Confirmed [6]). Attacker infrastructure used hostnames matching the victim's own and VPS addresses in the victim's country (Confirmed [6]).

Kevin Mandia testified that FireEye decompiled an update of about 18,000 files and 3,500 executables to find the implant (Confirmed [45]).

The second stage: TEARDROP, Raindrop and Cobalt Strike

For chosen victims the operators moved off SUNBURST to separate loaders. TEARDROP and Raindrop are custom loaders that decode and run Cobalt Strike Beacon; TEARDROP can run as a service DLL and is memory-only (Confirmed [11][6]). Raindrop, discovered by Symantec, uses a custom packer and hides its payload inside a modified 7-Zip code base; SUNBURST did not deliver it directly, and Symantec saw it at three victims with four samples, one installed at a victim in late May 2020 (Confirmed [8]). Microsoft documented the handoff: an Image File Execution Options debugger value on dllhost.exe launched wscript.exe, which launched rundll32 to run the loader (Confirmed [11]). Around it the operators changed audit policy with auditpol, added temporary netsh firewall rules, timestomped files to match arp.exe, ran a renamed AdFind and archived data with 7-Zip (Confirmed [11]). Almost every Cobalt Strike Beacon had its own command-and-control address, which weakened indicators shared between victims (Confirmed [11]). Microsoft assesses that hands-on-keyboard activity most likely started as early as May 2020 (Confirmed [11]).

Later tools came to light in 2021. Microsoft documented GoldMax, GoldFinder and Sibot, observed from August to September 2020 with possible compromise from June 2020 (Confirmed [26]); Mandiant reported SUNSHUTTLE, uploaded to a public repository by a US entity in August 2020 (Confirmed [68]); CrowdStrike reported TrailBlazer and a Linux GoldMax variant on victims from mid-2019 (Confirmed [78]).

The cloud follow-on: Golden SAML and application credentials

The step from an on-premises foothold to the cloud was where much of the value lay. Microsoft and Mandiant describe it in the same terms (Confirmed [22][23][29]):

- theft of the AD FS token-signing certificate, then forged SAML tokens, the attack known as Golden SAML;
- added or modified federation trusts (Confirmed [22][23]; that this let the tenant accept attacker-signed tokens is Inferred);
- credentials added to existing service principals and OAuth applications, then Microsoft Graph API calls to read mail;
- abuse of privileged cloud accounts synced from on premises, and, in an October 2021 update, abuse of cloud service provider trust (Confirmed [23]).

George Kurtz testified that Golden SAML let the actor move from on premises into the cloud and bypass MFA, a technique documented in 2017 (Confirmed [45]). CyberArk's shimit tool had implemented the forgery publicly since November 2017 (Demonstrated [92]). Brad Smith testified that forged SAML tokens were relevant in only about 15 percent of the cases Microsoft saw, and only after elevated access had been gained (Confirmed [45]). Microsoft's own investigation found that the actor viewed and downloaded source code for small subsets of Azure, Intune and Exchange components, changed no code, reached no production services or customer data, and did not use SAML techniques against Microsoft corporate domains (Confirmed [27][28]).

Paths that did not go through Orion

CISA's AA20-352A states that some victims were reached by password guessing and spraying, poorly secured administrator credentials and external remote services, not the Orion update (Confirmed [12]). Volexity worked three incidents at one US think tank from late 2019 to July 2020. In the second, the actor exploited CVE-2020-0688 on the Exchange Control Panel, stole the Duo integration secret key from the Outlook Web App server and forged a duo-sid cookie to pass MFA; Volexity says the weakness was in how the integration was secured, not a flaw in Duo. Mailboxes were exported with New-MailboxExportRequest. The third incident came through a backdoored Orion server in June and July 2020 (Confirmed [10]). The CISA and NIST supply-chain guide uses SolarWinds as its worked example and also stresses legitimate credentials and non-supply-chain vectors (Confirmed [88]).

SUPERNOVA is a different story

SolarWinds' advisory describes SUPERNOVA, a web shell on Orion servers, as a separate issue (Confirmed [17]). CISA AR21-112A assesses that the SUPERNOVA actor is separate from the APT actor behind the supply-chain compromise, with activity from at least March 2020 to February 2021 through Pulse Secure access and likely CVE-2020-10148 (Confirmed [79]). Secureworks attributes the SUPERNOVA intrusions it worked to a group it calls SPIRAL, unrelated to SUNBURST, and only tentatively suggests China, on the strength of a China-geolocated address that was likely exposed by accident (Confirmed [80]). CVE-2020-10148 is the Orion API authentication bypass, CWE-288, published 29 December 2020 and added to the KEV catalog on 3 November 2021 (Confirmed [33][32]). Neither ATT&CK C0024 nor AA20-352A mentions SUPERNOVA or CVE-2020-10148, so this study keeps them out of the campaign mappings (Inferred from [1][12]).

Discrepancies in the record

- **First access.** January 2019 per the SEC complaint and GAO; August 2019 per ATT&CK, and Unit 42 dates the earliest actor C2 domain, incomeupdate[.]com, to 6 August 2019; September 2019 per SolarWinds, with the timeline graphic giving 4 September (Confirmed [40][44][1][69][9][13]); a trade outlet reproduced the same day-level dates (Reported [84]). These are not necessarily in conflict: they measure different things (VPN access, infrastructure registration, activity SolarWinds itself found) (Inferred).
- **The test run.** 12 September to 4 November 2019 on SolarWinds' graphic; October 2019 in SolarWinds' blog and in Mandia's testimony; November 2019 in the SEC complaint (Confirmed [13][9][45][40]).
- **Affected versions.** ED 21-01 initially covered Orion 2019.4 through 2020.2.1 HF1, a broader range than the three affected builds SolarWinds lists (Confirmed [25][17]; Inferred that the directive erred on the side of caution).
- **When the campaign began.** FireEye wrote the campaign may have begun as early as spring 2020, and AA20-352A said at least March 2020, before the earlier build-server timeline was known (Confirmed [6][12] for the dates; Inferred for the explanation).
- **Counts.** "18,000" is the ceiling on installs, not compromises (Confirmed [14][52]). The White House fact sheet speaks of potential reach to more than 16,000 systems worldwide (Confirmed [54]).

Part 2: the timeline

Date	Event	Source	Grade
Nov 2017	CyberArk's shimit, a public Golden SAML implementation, is published	[92]	Demonstrated
Jan 2019	Alleged earliest confirmed access: SolarWinds' VPN reached through an unmanaged device and stolen credentials; recon and credential harvesting allegedly continue to Nov 2020	[40][44]	Confirmed (allegation; GAO statement)
6 Aug 2019	Earliest actor C2 domain, incomeupdate[.]com, per Unit 42	[69]	Confirmed
Aug 2019	ATT&CK C0024 first seen	[1]	Confirmed
4 Sep 2019	Threat actor accesses SolarWinds, per SolarWinds' timeline graphic	[13][9]	Confirmed
12 Sep to 4 Nov 2019	Test code injection (trial run)	[13]	Confirmed
Oct 2019	Orion release carries test modifications, empty classes	[9][20][45]	Confirmed
Late 2019	First Dark Halo incident at a US think tank (Volexity)	[10]	Confirmed
Dec 2019 to Dec 2020	Alleged exfiltration of about 7 million emails from more than 70 SolarWinds employees	[40]	Confirmed (allegation)
20 Feb 2020	SUNSPOT build timestamp; SUNBURST injected into Orion builds from this day	[7][9]	Confirmed
Mar 2020	CISA: compromises began at least this early	[12]	Confirmed
24 Mar 2020	Trojanized DLL signed by SolarWinds	[6]	Confirmed
26 Mar 2020	Hotfix 5 DLL available to customers	[13]	Confirmed
Mar to Jun 2020	Trojanized Orion updates released (the 8-K's Relevant Period)	[14][16]	Confirmed
May 2020	Hands-on-keyboard activity most likely begins; Raindrop installed at a victim in late May	[11][8]	Confirmed
May to Jun 2020	A US agency allegedly sees Orion contacting unknown sites after a May install and notifies SolarWinds in June	[40]	Confirmed (allegation)

Date	Event	Source	Grade
4 Jun 2020	Actor removes the malware from SolarWinds' build VMs	[13][9]	Confirmed
Jun to Jul 2020	Third Dark Halo incident, via Orion	[10]	Confirmed
16 Jul 2020	NCSC and CSE, with NSA and CISA, call APT29 almost certainly part of Russian intelligence over COVID-19 vaccine targeting	[73]	Confirmed
Aug 2020	SUNSHUTTLE uploaded to a public repository by a US entity	[68]	Confirmed
Aug to Sep 2020	GoldMax in use, possibly from June	[26]	Confirmed
Late Nov 2020	First viewing of a file in a Microsoft source repository	[27]	Confirmed
8 Dec 2020	FireEye discloses the theft of its red-team tools and releases more than 300 countermeasures	[47][48][49]	Confirmed
12 Dec 2020	SolarWinds notified, by a FireEye executive	[19][9]	Confirmed
13 Dec 2020	Mandiant publishes SUNBURST and countermeasures; CISA issues ED 21-01; Microsoft's same-day statement; SolarWinds notifies about 33,000 customers	[6][50][25][30][14]	Confirmed
14 Dec 2020	SolarWinds 8-K; Volexity publishes Dark Halo; Microsoft customer guidance	[14][10][29]	Confirmed
15 Dec 2020	SolarWinds releases Orion 2020.2.1 HF 2	[19]	Confirmed
16 Dec 2020	FBI, CISA and ODNI form a Cyber Unified Coordination Group	[51]	Reported
17 Dec 2020	CISA AA20-352A; Brad Smith reports more than 40 customers targeted; NSA advisory on authentication abuse	[12][31][90]	Confirmed
18 Dec 2020	Microsoft analysis of the compromised DLL; ED 21-01 supplemental guidance v1	[20][25]	Confirmed
21 Dec 2020	Microsoft recovery advice for systemic identity compromise	[91]	Confirmed
23 Dec 2020	Unit 42 SolarStorm timeline	[69]	Confirmed
24 Dec 2020	Mandiant additional technical details	[21]	Confirmed

Date	Event	Source	Grade
28 Dec 2020	Microsoft 365 Defender guidance on the cloud follow-on	[22]	Confirmed
29 Dec 2020	CVE-2020-10148 (SUPERNOVA path) published	[33]	Confirmed
30 Dec 2020	ED 21-01 supplemental guidance v2	[25]	Confirmed
31 Dec 2020	Microsoft: one internal account viewed source code	[28]	Confirmed
5 Jan 2021	Joint statement: APT actor likely Russian in origin, fewer than ten US agencies compromised	[52]	Confirmed
6 Jan 2021	ED 21-01 supplemental guidance v3	[25]	Confirmed
8 Jan 2021	CISA AA21-008A on detection in Microsoft cloud	[24]	Confirmed
11 Jan 2021	SolarWinds new findings and 8-K; CrowdStrike SUNSPOT; Kaspersky Kazuar overlaps	[9][15][7][70]	Confirmed
18 Jan 2021	Symantec publishes Raindrop	[8]	Confirmed
20 Jan 2021	Microsoft second-stage deep dive	[11]	Confirmed
Jan 2021	ATT&CK C0024 last seen	[1]	Confirmed
28 Jan 2021	Earliest tracking-only NOBELIUM emails of the Constant Contact campaign	[61]	Confirmed
Feb 2021	NOBELIUM's EnvyScout, BoomBox, NativeZone and VaporRage seen in the wild	[62]	Confirmed
17 Feb 2021	White House: nine agencies and about 100 companies compromised	[53]	Confirmed
18 Feb 2021	Microsoft final internal Solorigate update	[27]	Confirmed
23 Feb 2021	Senate Intelligence Committee open hearing	[45]	Confirmed
26 Feb 2021	House Oversight and Homeland Security joint hearing	[46]	Confirmed
1 Mar 2021	SolarWinds 10-K	[16]	Confirmed
4 Mar 2021	Microsoft names NOBELIUM and GoldMax, GoldFinder, Sibot; Mandiant publishes SUNSHUTTLE	[26][68]	Confirmed

Date	Event	Source	Grade
8 Mar 2021	SolarWinds revokes its compromised code-signing certificate	[17][18]	Confirmed
15 Apr 2021	US attributes to the SVR, imposes sanctions; UK NCSC, FCDO and NATO statements; NSA-CISA-FBI advisory on five CVEs; AA20-352A and AA21-008A revised	[54][55][56][71][72][57][12][24]	Confirmed
Apr 2021	FoggyWeb in use from this month at the earliest; CISA and NIST supply-chain guide	[64][88]	Confirmed
22 Apr 2021	ED 21-01 supplemental guidance v4; CISA AR21-112A on SUPERNOVA	[25][79]	Confirmed
26 Apr 2021	CISA AA21-116A on SVR trends	[58]	Confirmed
12 May 2021	Executive Order 14028 signed	[59][60]	Confirmed
18 May 2021	SVR director denies responsibility in a BBC interview	[74]	Reported
25 to 27 May 2021	NOBELIUM phishes about 3,000 accounts at more than 150 organizations from USAID's Constant Contact account	[61]	Confirmed
25 Jun 2021	Microsoft: password spraying across 36 countries, three compromised	[63]	Confirmed
12 Jul 2021	NTIA SBOM minimum elements	[97]	Confirmed
16 Jul 2021	ED 21-01 v4 deadline	[25]	Confirmed
27 Sep 2021	Microsoft publishes FoggyWeb	[64]	Confirmed
24 to 25 Oct 2021	Microsoft: NOBELIUM targets resellers and providers; DAP abuse	[65][66]	Confirmed
3 Nov 2021	CVE-2020-10148 and CVE-2020-0688 added to KEV	[32]	Confirmed
6 Dec 2021	Mandiant reports UNC3004 and UNC2652	[67]	Confirmed
13 Jan 2022	GAO-22-104746	[44]	Confirmed
Feb 2022	NIST SP 800-218 SSDF v1.1	[87]	Confirmed
10 Mar 2022	SolarWinds describes its next-generation build system	[85]	Confirmed

Date	Event	Source	Grade
27 Apr 2022	Mandiant merges UNC2452 into APT29	[77]	Confirmed
11 Jul 2022	CSRB's first report covers Log4j, not SolarWinds	[93]	Confirmed
14 Sep 2022	OMB M-22-18 on secure-development attestation	[98]	Confirmed
18 Apr 2023	Microsoft moves to weather names; NOBELIUM becomes Midnight Blizzard	[75][26]	Confirmed
18 Jul 2023	SolarWinds says its build system meets or exceeds SSDF guidance	[86]	Confirmed
30 Oct 2023	SEC charges SolarWinds and its CISO	[41][40]	Confirmed
20 Nov 2025	SEC case dismissed with prejudice by joint stipulation	[43][42]	Confirmed
8 Jan 2026	CISA sunsets ED 21-01	[25]	Confirmed

Part 3: identity, aliases and attribution

Many names, one actor

The actor collected a name from nearly every responder before anyone named a country. FireEye called it UNC2452 on 13 December 2020 with no state attribution or confidence level (Confirmed [6]); its red-team disclosure five days earlier spoke only of a highly sophisticated state-sponsored adversary and did not mention SolarWinds (Confirmed [48]). Volexity tracked Dark Halo and found no hints of origin and no links to any publicly known actor, tying its cases to UNC2452 through overlapping C2 domains and a backdoored Orion server (Confirmed [10]). Unit 42 called the operators SolarStorm, suspected nation-state operators (Confirmed [69]). CrowdStrike tracked the StellarParticle cluster and did not attribute SUNSPOT to a known adversary in January 2021 (Confirmed [7]). Microsoft introduced NOBELIUM in March 2021, framed as an assessment (Confirmed [26]), and since April 2023 tracks it as Midnight Blizzard, the Blizzard family being Russia (Confirmed [75][76]).

Microsoft's naming page lists Midnight Blizzard's other names as NOBELIUM, COZY BEAR, UNC2452 and APT29 (Confirmed [76]). ATT&CK's G0016 APT29 page attributes the group to the SVR, operating since at least 2008, with aliases that include Dark Halo, NOBELIUM, UNC2452, YTTRIUM, The Dukes, Cozy Bear, CozyDuke, SolarStorm, UNC3524 and Midnight Blizzard; StellarParticle is not an alias there but the industry name for campaign C0024 (Confirmed [81][1]). The legacy ATT&CK id G0118 now redirects to G0016 (Confirmed [82]); that G0118 was once the separate UNC2452 entry is Inferred and not re-verified.

The Kazuar overlap

Kaspersky found three code overlaps between SUNBURST and Kazuar, a backdoor earlier tied to Turla: the sleep algorithm, a modified FNV-1a hash and UID generation (Confirmed [70]). Kaspersky listed several explanations, from shared developers to borrowed ideas to a false flag, said it did not know which was true, and said it was not claiming that Dark Halo or UNC2452 and Turla are the same (Confirmed [70]). The overlap is a lead, not an attribution (Inferred).

From "nation-state" to "SVR, high confidence"

Date	Who	What they said	Source	Grade
13 Dec 2020	FireEye	UNC2452, no country	[6]	Confirmed
17 Dec 2020	Microsoft	A nation-state attack; Russia not named; more than 40 customers targeted, about 80 percent in the US, the rest in Canada, Mexico, Belgium, Spain, the UK, Israel and the UAE	[31]	Confirmed
17 Dec 2020	CISA	An APT actor	[12]	Confirmed
5 Jan 2021	FBI, CISA, ODNI, NSA	An APT actor likely Russian in origin, responsible for most or all compromises; an intelligence-gathering effort	[52]	Confirmed
11 Jan 2021	SolarWinds	Perpetrators not independently verified	[9]	Confirmed
1 Mar 2021	SolarWinds 10-K	No independent attribution	[16]	Confirmed
15 Apr 2021	White House	The SVR (APT 29, Cozy Bear, The Dukes), high confidence	[54]	Confirmed
15 Apr 2021	Treasury	SVR responsible for the Orion exploit and the red-team tool theft; Pasit and SVA designated for supporting SVR cyber operations	[55]	Confirmed
15 Apr 2021	UK NCSC	Highly likely the SVR	[56]	Confirmed
15 Apr 2021	UK FCDO	Russian Intelligence Services; Russian ambassador summoned	[71]	Confirmed
15 Apr 2021	NATO	All available evidence points to Russian responsibility	[72]	Confirmed
26 Apr 2021	CISA AA21-116A	SVR cyber actors equated with APT 29, the Dukes, CozyBear and Yttrium; the supply-chain vector a notable departure from historic tradecraft	[58]	Confirmed
18 May 2021	SVR director	Denial, in a BBC interview relayed by RFE/RL	[74]	Reported
27 Jan 2022	CrowdStrike	StellarParticle associated with COZY BEAR; SVR attribution credited to the US government	[78]	Confirmed
27 Apr 2022	Mandiant	Sufficient evidence that UNC2452 is APT29, from firsthand data	[77]	Confirmed

The UK FCDO page does not name the SVR, and the NCSC page names none of the aliases (Confirmed [71][56]). Mandiant's 2021 clusters UNC3004 and UNC2652 were associated with UNC2452 without

high-confidence evidence (Confirmed [67]). Microsoft's October 2021 reseller report ties NOBELIUM to the 2020 SolarWinds compromise and does not mention the SVR (Confirmed [66]). The White House tied attribution to costs: a new sanctions executive order, sovereign-debt restrictions, six Russian technology companies designated, 32 entities and individuals sanctioned for election interference and ten diplomatic personnel expelled (Confirmed [54]).

The same actor, before and after

APT29's record did not start here. ATT&CK lists one other campaign for G0016, C0023 Operation Ghost, from September 2013 to October 2019 (Confirmed [81]). In July 2020, before SolarWinds was known, NCSC and CSE assessed APT29 as almost certainly part of Russian intelligence for targeting COVID-19 vaccine research with WellMess and WellMail (Confirmed [73]). After the disclosure, NOBELIUM ran the Constant Contact phishing campaign spoofing USAID (Confirmed [61]), an early-stage toolset of EnvyScout, BoomBox, NativeZone and VaporRage (Confirmed [62]), password spraying in 36 countries that compromised three entities, during which Microsoft also found information-stealing malware on a machine belonging to one of its customer support agents (Confirmed [63]), FoggyWeb on AD FS servers (Confirmed [64]), and a reseller campaign in which more than 140 providers were notified, as many as 14 compromised, and 22,868 attacks were made on 609 customers between 1 July and 19 October 2021 (Confirmed [65]). Mandiant reported residential proxies, CEELOADER and CRYPTBOT session-token theft in the 2021 clusters (Confirmed [67]).

Part 4: the government and legal record

The emergency response

CISA issued Emergency Directive 21-01 on 13 December 2020, ordering federal agencies to disconnect or power down affected Orion products, followed by supplemental guidance on 18 December, 30 December and 6 January, and a fourth version on 22 April 2021 with a 16 July 2021 deadline; CISA sunset the directive on 8 January 2026 (Confirmed [25]). A Cyber Unified Coordination Group of the FBI, CISA and ODNI formed under PPD-41 on 16 December 2020 (Reported [51], read through a reproduction because the CISA original returned 404). GAO later found two Cyber UCGs and lessons on private-sector coordination, slow information sharing and uneven evidence preservation (Confirmed [44]).

Anne Neuberger's 17 February 2021 briefing gave the scale: nine federal agencies and about 100 private-sector companies compromised, about 18,000 downloads, and an operation launched from inside the United States, which limited the intelligence community's visibility (Confirmed [53]).

The hearings

The Senate Select Committee on Intelligence heard Kevin Mandia, Sudhakar Ramakrishna, Brad Smith and George Kurtz on 23 February 2021; AWS declined to attend (Confirmed [45]). Smith cited a Microsoft estimate of at least 1,000 engineers behind the effort, which is Microsoft's estimate and not a measured figure (Confirmed as Microsoft's estimate [45]). Senators and witnesses debated mandatory breach notification (Confirmed [45]). At the House Oversight and Homeland Security joint hearing on 26 February 2021, the former SolarWinds CEO attributed the "SolarWinds123" password to an intern who posted it on GitHub (Confirmed [46]); no opened source ties that password to the intrusion path (Inferred).

Policy that followed

- **Executive Order 14028 (12 May 2021).** Removes contract barriers to incident sharing, sets Zero Trust plans in 60 days and MFA and encryption in 180 days, defines critical software, calls for SBOM minimum elements, secure-development attestation and provenance, creates the Cyber Safety Review Board, and requires federal EDR and logging (Confirmed [59][60]). Section 5 directs the Board's first review to the activity that prompted the December 2020 UCG, within 90 days (Confirmed [60]).
- **NTIA SBOM minimum elements (12 July 2021).** Data fields, automation support in SPDX, CycloneDX or SWID, and practices and processes (Confirmed [97]).
- **NIST SP 800-218 SSDF v1.1 (February 2022).** Published in response to the order's Section 4 (Confirmed [87]).
- **OMB M-22-18 (14 September 2022).** Producer self-attestation to NIST secure-development guidance, plans of action for gaps, optional SBOMs; critical software within 270 days and all covered software within 365 (Confirmed [98]).
- **The review that did not happen.** The CSRB's first report covered Log4j; SolarWinds appears only as a comparison, including about 14 months of actor access (Confirmed [93]). ProPublica reported that the Board never reviewed SolarWinds, that DHS called the 90-day deadline unachievable, and that GAO accepted the mandate as implemented on the strength of the Log4j report and a non-public NSC review (Reported [94]). The Board's non-government memberships were ended by a DHS memo of 20 January 2025 (Reported [95]).
- **Think-tank verdict.** The Atlantic Council's "Broken Trust" called Sunburst a failure of strategy, found the worst harm came through Microsoft identity and cloud products, and recommended an SBOM glide path among twelve recommendations (Confirmed [96]).

The SEC case

On 30 October 2023 the SEC charged SolarWinds and its CISO over statements about cyber controls from the October 2018 IPO to the December 2020 disclosure (Confirmed [41]). The complaint alleges the January 2019 VPN access, repeated access and credential harvesting into November 2020, exfiltration of about 7 million emails, the June 2020 agency notification and about 100 of 18,000 customers hit by secondary attacks (Confirmed as allegations [40][43]). The case was dismissed with prejudice by joint stipulation filed 20 November 2025 (Confirmed [42][43]). A July 2024 court ruling in the case was not checked for this study.

Part 5: the vulnerability-management view

SolarWinds is a hard case for a vulnerability program because the dangerous thing had no CVE. SUNBURST is malicious code shipped in a legitimate, signed product, not a flaw; the primary record assigns it neither a CVE nor a CWE (Inferred from [17][33][35]). The scanners that mattered in December 2020 were software inventory, not vulnerability scanners: which hosts ran Orion 2019.4 HF 5, 2020.2 or 2020.2 HF 1 (Confirmed [17]; Inferred for the lesson).

Item	What it is	Record	Source	Grade
Orion 2019.4 HF 5, 2020.2, 2020.2 HF 1	The three affected builds	SolarWinds advisory and FAQ	[17][18]	Confirmed

Item	What it is	Record	Source	Grade
Orion 2020.2.1 HF 2	Remediated release, 15 Dec 2020	SolarWinds blog	[19]	Confirmed
Code-signing certificate	Revoked 8 Mar 2021	SolarWinds advisory	[17]	Confirmed
CVE-2020-10148	Orion API authentication bypass used with SUPERNOVA; CWE-288; KEV 3 Nov 2021, due 3 May 2022	CNA record, KEV	[33][32]	Confirmed
CVE-2020-0688	Exchange Control Panel flaw in Volexity's second incident; CNA gives only "Remote Code Execution", CISA's ADP gives CWE-287; KEV 3 Nov 2021	CVE record, KEV	[34][32][10]	Confirmed
CVE-2019-11510, CVE-2020-1472, CVE-2018-13379, CVE-2019-19781, CVE-2020-0688	Among 16 prioritized CVEs targeted by FireEye's stolen red-team tools	FireEye countermeasures	[49]	Confirmed
CVE-2018-13379, CVE-2019-9670, CVE-2019-11510, CVE-2019-19781, CVE-2020-4006	Five CVEs the SVR exploited, per the 15 Apr 2021 joint advisory	NSA-CISA-FBI, via CISA	[57]	Confirmed

The two CVE lists are different claims: the FireEye list is what the stolen tools could exploit, the joint-advisory list is what the SVR was seen exploiting (Inferred). FireEye said its stolen tools held no zero-days (Confirmed [47]). AA21-116A also names CVE-2019-19781 and Office 365 password spraying in the SVR's playbook (Confirmed [58]).

Two practical points for a vulnerability-management team (Inferred from the record above). First, a supplier advisory that names versions is the trigger, and the inventory system has to answer it in hours; CISA's directive ordered agencies to disconnect or power down affected Orion on 13 December 2020, the day SUNBURST was published (Confirmed [25][6]). Second, removing the vulnerable build was necessary but not sufficient: the backdoor was the door, and the threat was what had already walked through it, so the remediation ticket for an exploited host is an incident, not a patch (Confirmed [12] for CISA's rebuild guidance).

Part 6: the defender view

Build integrity

SolarWinds' rebuilt pipeline uses ephemeral build resources, three parallel environments (standard, a validation build with no internet ingress or egress, and a security build), signed build-step records in an immutable ledger and deterministic reproducibility checks (Confirmed [85]). SolarWinds says the system meets or exceeds SSDF guidance; that is a self-assessment with no attestation shown (Confirmed as SolarWinds' claim [86]). The SSDF maps the lesson: PO.5.1 separates and protects development environments, PS.2.1 gives acquirers integrity verification, PS.3.2 collects and shares provenance such as an SBOM, and a PO.3 example names reproducible builds (Confirmed [87]). Code signing did not help because signing happened after the source swap; an independent reproducible build with output comparison is the control that exposes a compile-time swap (Inferred [7]).

Network signals

SUNBURST's first observable was most likely a monitoring server resolving avsvmcloud[.]com subdomains (Inferred from [6]). CISA noted the subdomains were victim-specific, that an additional CNAME resolution suggested further adversary activity, and that by 15 December 2020 the domain resolved to an address on a Microsoft blocklist (Confirmed [12]). FireEye worked with GoDaddy and Microsoft to turn the domain into a kill switch that stopped still-beaconing implants but not backdoors already placed (Reported [89]). Mandiant published Snort and YARA rules, FNV-1a XOR hashes and indicators on GitHub the day of disclosure (Confirmed [50]). Its hunt ideas still read well: attacker hostnames matching victim names, VPS addresses in the victim's country, impossible travel, one host authenticating to many systems, temporary replace-execute-restore of utilities and briefly modified scheduled tasks (Confirmed [6]). Egress restriction for management servers and retained passive DNS are what made retro-hunting possible (Inferred).

Host signals for the second stage

Microsoft's hunt points: an IFEO debugger value on dllhost.exe that launches wscript.exe and then rundll32, AUDITPOL changes, temporary netsh rules, 7-Zip archiving and a renamed AdFind (Confirmed [11]). Almost every Beacon had unique infrastructure, which weakened indicators shared between victims (Confirmed [11]); behavior hunts are the better bet (Inferred).

Identity signals

- Detect "impossible tokens": odd lifetimes, issue time equal to use time, no matching login, missing MFA claims (Confirmed [12]).
- Correlate cloud logins with AD FS and domain controller events (4769, 1200, 1202); watch Export-PfxCertificate or certutil in PowerShell logs (4103, 4104) and AD FS configuration change Event 307 with 510 (Confirmed [24]).
- Use the tools CISA named, Sparrow, CrowdStrike CRT and Hawk; note that MailItemsAccessed needed E5 or G5 licensing at the time (Confirmed [24]).
- Review "Set domain authentication" events, hunt added service-principal credentials and treat unexpected "MFA satisfied by claim in the token" as an indicator (Confirmed [91]).
- NSA's "Detecting Abuse of Authentication Mechanisms" covers forged-credential access to cloud data (Confirmed through CISA's alert [90]; the NSA PDF returned 403).

Recovery

Roll the AD FS token-signing certificate twice, because a single roll leaves the old one valid during a grace period; reset krbtgt twice (Confirmed [91][12]). CISA judged a full rebuild the safest action (Confirmed [12]). Microsoft's own lessons: assume breach, protect privileged credentials, take care with hybrid identity (Confirmed [27]).

Part 7: MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0, CAPEC, CWE and D3FEND. Every id was checked against the live MITRE page or the library's data files on 3 November 2026 (Confirmed [1][2][3][4][5][39]). The SolarWinds record has no ICS techniques, so there is no ATT&CK for ICS table (Inferred [1]).

ATT&CK Enterprise techniques

The library's generated pages for C0024, S0559, S0560, S0562 and S0565 list exactly the leaf techniques the live ATT&CK pages list: C0024 71, S0559 36, S0560 6, S0562 12, S0565 7 (Confirmed [39]). Together the five objects cover 103 distinct techniques; vendor and government reports add nine more, for 112 (Confirmed [39]). Tactic names follow ATT&CK v20.0, which splits the former Defense Evasion tactic into Stealth and Defense Impairment: T1553.002 Code Signing is now Defense Impairment, while T1027, T1036.005 and the T1070 sub-techniques are Stealth (Confirmed [1][39]). Microsoft's 2021 report used T1562.001, T1562.002 and T1562.004; all three are revoked, and the library's `data/attack/superseded_by.jsonl` maps them to T1685, T1685.001 and T1686, which the table uses (Confirmed [11][39]). CISA's AA20-352A text labels password guessing and spraying as T1101.001 and T1101.003, but its links point to T1110.001 and T1110.003, which the table uses (Confirmed [12]).

Source numbers [1] to [5] mean the technique is on that ATT&CK object; "underlying reports not opened" marks ATT&CK procedures whose cited reports (MSRC, NCSC and CrowdStrike StellarParticle) this study did not open.

Id	Name	Tactic (v20.0)	Where it appears in the SolarWinds record	Source
T1001.001	Junk Data	Command and Control	SUNBURST S0559 (in Orion builds, Mar to Jun 2020)	[2]
T1001.002	Steganography	Command and Control	SUNBURST S0559 (in Orion builds, Mar to Jun 2020)	[2]
T1001.003	Protocol or Service Impersonation	Command and Control	C2 traffic disguised as the Orion Improvement Program protocol (Mandiant, 13 Dec 2020)	[2][6]
T1003.006	DCSync	Credential Access	DCSync (ATT&CK C0024; underlying reports not opened)	[1]
T1005	Data from Local System	Collection	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021); SUNBURST S0559 (in Orion builds, Mar to Jun 2020)	[1][2]
T1007	System Service Discovery	Discovery	SUNBURST S0559 (in Orion builds, Mar to Jun 2020)	[2]
T1012	Query Registry	Discovery	SUNBURST reads the MachineGuid value (Mandiant, 24 Dec 2020)	[2][3][21]
T1016	System Network Configuration Discovery	Discovery	SUNBURST S0559 (in Orion builds, Mar to Jun 2020)	[2]
T1016.001	Internet Connection Discovery	Discovery	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1018	Remote System Discovery	Discovery	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1021.001	Remote Desktop Protocol	Lateral Movement	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1021.002	SMB/Windows Admin Shares	Lateral Movement	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]

Id	Name	Tactic (v20.0)	Where it appears in the SolarWinds record	Source
T1021.006	Windows Remote Management	Lateral Movement	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1027	Obfuscated Files or Information	Stealth	SUNBURST compressed, encoded and hashed strings (Microsoft, 18 Dec 2020); SUNSPOT AES blobs	[2][3][4][7][20]
T1027.002	Software Packing	Stealth	Raindrop custom packer (Symantec, 18 Jan 2021)	[5][8]
T1027.003	Steganography	Stealth	Raindrop payload hidden inside modified 7-Zip code (Symantec, 18 Jan 2021)	[5][8]
T1027.005	Indicator Removal from Tools	Stealth	SUNBURST S0559 (in Orion builds, Mar to Jun 2020)	[2]
T1027.013	Encrypted/Encoded File	Stealth	Raindrop encrypted payload (Symantec, 18 Jan 2021)	[5][8]
T1027.015	Compression	Stealth	SUNBURST compressed strings (Microsoft, 18 Dec 2020)	[2][20]
T1033	System Owner/User Discovery	Discovery	SUNBURST S0559 (in Orion builds, Mar to Jun 2020)	[2]
T1036	Masquerading	Stealth	Raindrop S0565 (Symantec, 18 Jan 2021)	[5]
T1036.004	Masquerade Task or Service	Stealth	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1036.005	Match Legitimate Resource Name or Location	Stealth	Renamed AdFind; SUNSPOT log disguised as vmware-vmdmp.log	[1][2][3][4][5][7][11]
T1047	Windows Management Instrumentation	Execution	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021); SUNBURST S0559 (in Orion builds, Mar to Jun 2020)	[1][2]
T1048.002	Exfiltration Over Asymmetric Encrypted Non-C2 Protocol	Exfiltration	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1053.005	Scheduled Task	Execution, Persistence, Privilege Escalation	Scheduled tasks briefly modified to run tools (Mandiant, 13 Dec 2020); SUNSPOT boot-time task	[1][6][7]
T1057	Process Discovery	Discovery	SUNSPOT polls for MsBuild.exe every second; SUNBURST process blocklist	[1][2][4][7]
T1059.001	PowerShell	Execution	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1059.003	Windows Command Shell	Execution	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]

Id	Name	Tactic (v20.0)	Where it appears in the SolarWinds record	Source
T1059.005	Visual Basic	Execution	wscript stage of the SUNBURST to Cobalt Strike handoff (Microsoft, 20 Jan 2021)	[1][2][11]
T1069	Permission Groups Discovery	Discovery	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1069.002	Domain Groups	Discovery	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1070	Indicator Removal	Stealth	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021); SUNBURST S0559 (in Orion builds, Mar to Jun 2020)	[1][2]
T1070.004	File Deletion	Stealth	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021); SUNBURST S0559 (in Orion builds, Mar to Jun 2020); SUNSPOT S0562 (build implant, timestamp 20 Feb 2020)	[1][2][4]
T1070.006	Timestomp	Stealth	Timestamps altered to match arp.exe (Microsoft, 20 Jan 2021)	[1][11]
T1070.007	Clear Network Connection History and Configurations	Stealth	SUNBURST S0559 (in Orion builds, Mar to Jun 2020)	[2]
T1070.008	Clear Mailbox Data	Stealth	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1070.009	Clear Persistence	Stealth	SUNBURST S0559 (in Orion builds, Mar to Jun 2020)	[2]
T1071.001	Web Protocols	Command and Control	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021); SUNBURST S0559 (in Orion builds, Mar to Jun 2020)	[1][2]
T1071.004	DNS	Command and Control	DNS beaconing to DGA subdomains of avsvmcloud[.]com with CNAME handoff (Mandiant, 13 Dec 2020)	[2][6]
T1074.002	Remote Data Staging	Collection	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1078	Valid Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	Legitimate credentials used after initial access (ATT&CK C0024; CISA and NIST supply-chain guide)	[1][88]
T1078.002	Domain Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1078.003	Local Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]

Id	Name	Tactic (v20.0)	Where it appears in the SolarWinds record	Source
T1078.004	Cloud Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	Abuse of synced privileged cloud accounts (Mandiant Microsoft 365 guide, 2021)	[1][23]
T1082	System Information Discovery	Discovery	SUNBURST S0559 (in Orion builds, Mar to Jun 2020)	[2]
T1083	File and Directory Discovery	Discovery	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021); SUNBURST S0559 (in Orion builds, Mar to Jun 2020); SUNSPOT S0562 (build implant, timestamp 20 Feb 2020)	[1][2][4]
T1087	Account Discovery	Discovery	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1087.002	Domain Account	Discovery	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1090.001	Internal Proxy	Command and Control	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1098.001	Additional Cloud Credentials	Persistence, Privilege Escalation	Credentials added to service principals and OAuth applications (Microsoft, 28 Dec 2020)	[1][12][22][23]
T1098.002	Additional Email Delegate Permissions	Persistence, Privilege Escalation	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1098.003	Additional Cloud Roles	Persistence, Privilege Escalation	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1098.005	Device Registration	Persistence, Privilege Escalation	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1105	Ingress Tool Transfer	Command and Control	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021); SUNBURST S0559 (in Orion builds, Mar to Jun 2020)	[1][2]
T1106	Native API	Execution	SUNSPOT S0562 (build implant, timestamp 20 Feb 2020)	[4]
T1110.001	Password Guessing	Credential Access	Password guessing as a non-Orion initial vector (AA20-352A, 17 Dec 2020; the text mislabels it T1101.001)	[12]
T1110.003	Password Spraying	Credential Access	Password spraying as a non-Orion initial vector (AA20-352A, 17 Dec 2020; the text mislabels it T1101.003)	[12]
T1112	Modify Registry	Defense Impairment, Persistence	SUNBURST disables services by setting their Start value to 4 (Mandiant, 24 Dec 2020)	[2][3][21]
T1114.002	Remote Email Collection	Collection	Mailboxes exported with New-MailboxExportRequest (Volexity, 14 Dec 2020)	[1][10]

Id	Name	Tactic (v20.0)	Where it appears in the SolarWinds record	Source
T1124	System Time Discovery	Discovery	SUNBURST S0559 (in Orion builds, Mar to Jun 2020)	[2]
T1132.001	Standard Encoding	Command and Control	SUNBURST S0559 (in Orion builds, Mar to Jun 2020)	[2]
T1133	External Remote Services	Persistence, Initial Access	External remote services as a non-Orion initial vector (AA20-352A, 17 Dec 2020)	[1][12]
T1134	Access Token Manipulation	Stealth, Privilege Escalation	SUNSPOT S0562 (build implant, timestamp 20 Feb 2020)	[4]
T1140	Deobfuscate/Decode Files or Information	Stealth	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021); TEARDROP S0560; SUNSPOT S0562 (build implant, timestamp 20 Feb 2020); Raindrop S0565 (Symantec, 18 Jan 2021)	[1][3][4][5]
T1190	Exploit Public-Facing Application	Initial Access	CVE-2020-0688 on the Exchange Control Panel, second Dark Halo incident at a US think tank (Volexity, 14 Dec 2020)	[1][10]
T1195.001	Compromise Software Dependencies and Development Tools	Initial Access	Listed in the AA20-352A technique table (17 Dec 2020); not on the ATT&CK objects	[12]
T1195.002	Compromise Software Supply Chain	Initial Access	SUNSPOT inserted SUNBURST into Orion builds from 20 Feb 2020; trojanized updates distributed Mar to Jun 2020	[1][4][6][7][9][14][83]
T1199	Trusted Relationship	Initial Access	Cloud partner accounts and Mimecast certificates (ATT&CK C0024; underlying reports not opened)	[1]
T1213	Data from Information Repositories	Collection	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1213.003	Code Repositories	Collection	Source code for subsets of Azure, Intune and Exchange components downloaded (MSRC, 18 Feb 2021)	[1][27]
T1218.011	Rundll32	Stealth	rundll32 launching the TEARDROP or Raindrop loader (Microsoft, 20 Jan 2021)	[1][2][11]
T1480	Execution Guardrails	Stealth	SUNSPOT target-file hash checks; SUNBURST runs only on domain-joined hosts	[4][6][7]
T1480.002	Mutual Exclusion	Stealth	SUNSPOT mutexes (CrowdStrike, 11 Jan 2021)	[4][7]
T1482	Domain Trust Discovery	Discovery	Domain trust discovery with AdFind (ATT&CK C0024)	[1]

Id	Name	Tactic (v20.0)	Where it appears in the SolarWinds record	Source
T1484.002	Trust Modification	Defense Impairment, Privilege Escalation	Federation trusts added or modified (Microsoft, 28 Dec 2020; AA20-352A)	[1][12][22]
T1497.001	System Checks	Stealth, Discovery	SUNBURST S0559 (in Orion builds, Mar to Jun 2020)	[2]
T1497.003	Time Based Checks	Stealth, Discovery	Dormancy of roughly 12 to 14 days before the first beacon (Mandiant, 13 Dec 2020)	[2][5][6]
T1518	Software Discovery	Discovery	Mandiant technique list (13 Dec 2020) and AA20-352A	[6][12]
T1518.001	Security Software Discovery	Discovery	Blocklists of security-tool processes, services and drivers (Mandiant, 24 Dec 2020)	[2][21]
T1539	Steal Web Session Cookie	Credential Access	Duo integration secret stolen from the OWA server (Volexity, 14 Dec 2020)	[1][10]
T1543.003	Windows Service	Persistence, Privilege Escalation	TEARDROP runs as a Windows service DLL (Microsoft, 20 Jan 2021)	[3][11]
T1546.003	Windows Management Instrumentation Event Subscription	Privilege Escalation, Persistence	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1546.012	Image File Execution Options Injection	Privilege Escalation, Persistence	dllhost.exe IFEO debugger value launching wscript (Microsoft, 20 Jan 2021)	[2][11]
T1550	Use Alternate Authentication Material	Lateral Movement	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1550.001	Application Access Token	Lateral Movement	Application tokens used for Graph API mail access (Microsoft, 14 Dec 2020)	[1][12][29]
T1550.004	Web Session Cookie	Lateral Movement	Forged duo-sid cookie used to bypass MFA (Volexity, 14 Dec 2020)	[1][10]
T1552.004	Private Keys	Credential Access	AD FS token-signing certificate theft (Microsoft, 28 Dec 2020; AA20-352A)	[1][12][22]
T1553.002	Code Signing	Defense Impairment	SUNBURST DLL signed with the SolarWinds certificate, 24 Mar 2020 (Mandiant, 13 Dec 2020); certificate revoked 8 Mar 2021	[1][2][6][17]
T1555	Credentials from Password Stores	Credential Access	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1555.003	Credentials from Web Browsers	Credential Access	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1558.003	Kerberoasting	Credential Access	Kerberoasting (ATT&CK C0024; underlying reports not opened)	[1]
T1560.001	Archive via Utility	Collection	7-Zip archiving before exfiltration (Microsoft, 20 Jan 2021)	[1][11]

Id	Name	Tactic (v20.0)	Where it appears in the SolarWinds record	Source
T1565.001	Stored Data Manipulation	Impact	SUNSPOT swapped InventoryManager.cs during MsBuild builds after MD5 checks, then restored it (CrowdStrike, 11 Jan 2021)	[4][7]
T1567.002	Exfiltration to Cloud Storage	Exfiltration	Exfiltration to cloud storage, mapped only by Microsoft (20 Jan 2021)	[11]
T1568	Dynamic Resolution	Command and Control	CNAME responses handed SUNBURST off to HTTP C2 (Mandiant, 13 Dec 2020)	[1][2][6]
T1568.002	Domain Generation Algorithms	Command and Control	DGA-built subdomains of avsvmcloud[.]com (Mandiant, 13 Dec 2020; AA20-352A, 17 Dec 2020); not on the ATT&CK objects	[6][12]
T1569.002	Service Execution	Execution	Mandiant technique list (13 Dec 2020) and AA20-352A	[6][12]
T1573.001	Symmetric Cryptography	Command and Control	SUNBURST S0559 (in Orion builds, Mar to Jun 2020)	[2]
T1583.001	Domains	Resource Development	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1584	Compromise Infrastructure	Resource Development	Mandiant technique list (13 Dec 2020) and AA20-352A	[6][12]
T1584.001	Domains	Resource Development	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1587.001	Malware	Resource Development	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1589.001	Credentials	Reconnaissance	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1592.002	Software	Reconnaissance	CrowdStrike technique list for SUNSPOT (11 Jan 2021)	[7]
T1606.001	Web Cookies	Credential Access	duo-sid cookie forged from the stolen secret (Volexity, 14 Dec 2020)	[1][10]
T1606.002	SAML Tokens	Credential Access	Forged SAML tokens, Golden SAML (AA20-352A; Microsoft, 13 and 28 Dec 2020)	[1][12][22][30]
T1665	Hide Infrastructure	Command and Control	C2 hostnames chosen to match victim hostnames (Mandiant, 13 Dec 2020)	[1][6]
T1680	Local Storage Discovery	Discovery	ATT&CK C0024 procedure (campaign Aug 2019 to Jan 2021)	[1]
T1685	Disable or Modify Tools	Defense Impairment	Security tools disabled; Microsoft reported tool tampering as revoked T1562.001 (20 Jan 2021)	[1][2][11][21]

Id	Name	Tactic (v20.0)	Where it appears in the SolarWinds record	Source
T1685.001	Disable or Modify Windows Event Log	Defense Impairment	auditpol changes; Microsoft reported them as revoked T1562.002 (20 Jan 2021)	[1][11]
T1686	Disable or Modify System Firewall	Defense Impairment	Temporary netsh firewall rules; Microsoft reported them as revoked T1562.004 (20 Jan 2021)	[1][11]

ATT&CK groups, software and campaigns

Object	Id	Role in the record	Source
SolarWinds Compromise	C0024	The campaign: first seen Aug 2019, last seen Jan 2021, v1.1 modified 31 Jul 2026; StellarParticle as the industry name; UNC2452, NOBELIUM, Dark Halo and SolarStorm as initial actor names	[1]
APT29	G0016	The group C0024 is attributed to; v6.2, attributed to the SVR	[81][1]
Operation Ghost	C0023	APT29's other ATT&CK campaign, Sep 2013 to Oct 2019	[81]
Turla	G0010	Group Kaspersky's Kazuar overlap points to; not an attribution	[70][39]
SUNBURST	S0559	The Orion backdoor; associated name Solorigate; used by APT29 since at least Feb 2020	[2]
SUNSPOT	S0562	The build implant; v1.2, modified 16 Apr 2025	[4]
TEARDROP	S0560	Memory-only Cobalt Strike loader, runs as a service	[3][6]
Raindrop	S0565	7-Zip-based Cobalt Strike loader; v1.3, modified 11 Apr 2024	[5][8]
Cobalt Strike	S0154	The Beacon payload of both loaders	[1][11]
AdFind	S0552	Renamed directory-discovery tool	[1][11]
Mimikatz	S0002	Credential tooling listed on C0024	[1]
GoldMax	S0588	Later-stage backdoor, Aug to Sep 2020	[1][26]
GoldFinder	S0597	Later-stage NOBELIUM tool	[1][26]
Sibot	S0589	Later-stage NOBELIUM tool	[1][26]
TrailBlazer	S0682	Reported by CrowdStrike on victims from mid-2019	[1][78]
Kazuar	S0265	Backdoor with three code overlaps with SUNBURST	[70][39]
WellMess, WellMail	S0514, S0515	APT29's COVID-19 vaccine targeting, Jul 2020	[73][39]
EnvyScout, BoomBox, VaporRage, NativeZone	S0634 to S0637	NOBELIUM's 2021 early-stage toolset	[62][39]
FoggyWeb	S0661	AD FS backdoor, in use from Apr 2021	[64][39]

The legacy id G0118 redirects to G0016 on the live site and has no library page, so only G0016 is linked (Confirmed [82][39]). SUNSHUTTLE, CEELOADER and CRYPTBOT are named in the vendor record but are not linked here because their ATT&CK ids were not checked.

CAPEC and CWE

Id	Name	Fit to this record	Source	Grade
CAPEC-678	System Build Data Maliciously Altered	Maps to T1195.002; the closest description of SUNSPOT's compile-time swap	[37][39]	Confirmed for the mapping; Inferred for the fit
CAPEC-673	Developer Signing Maliciously Altered Software	Maps to T1195.002; fits SUNBURST, signed by a developer who was not complicit; the page does not mention SolarWinds	[35][39]	Confirmed for the mapping; Inferred for the fit
CAPEC-511	Infiltration of Software Development Environment	Maps to T1195.001 on the live page; fits the build-server intrusion	[36]	Confirmed for the mapping; Inferred for the fit
CAPEC-206	Signing Malicious Code	One of the library's three CAPEC mappings for T1553.002 (with CAPEC-68 and CAPEC-473); fits best because SUNBURST was signed through the normal build, not with stolen keys	[39]	Inferred
CWE-288	Authentication Bypass Using an Alternate Path or Channel	CVE-2020-10148, the SUPERNOVA path, per the SolarWinds CNA record and KEV	[33][32]	Confirmed
CWE-287	Improper Authentication	CVE-2020-0688 per CISA's ADP container and KEV	[34][32]	Confirmed

The library maps eight CAPEC entries to T1195.002: CAPEC-186, 442, 443, 523, 669, 673, 678 and 691 (Confirmed [39]). CAPEC-691, Spoof Open-Source Software Metadata, does not fit a closed-source build attack (Inferred). CAPEC-678 and CAPEC-673 both say CWE does not cover supply chain the way CAPEC frames it, so neither lists a CWE (Confirmed [37][35]). SUNBURST itself has no CWE in the primary record; labelling it CWE-506 Embedded Malicious Code would be this study's inference, so no such id is bound here. See the CWE Reference and CAPEC Reference.

D3FEND countermeasures

The live D3FEND page for T1195.002 shows only an inferred Harden, Restore and Model relationship and no named countermeasures (Confirmed [38]). The library's `technique_to_d3fend.jsonl` carries named mappings (Confirmed [99]):

Countermeasure	Id	Library mapping to this study's techniques	Guidance in the record it matches	Source
Software Inventory	D3-SWI	T1195.002	Finding hosts running the three affected builds	[99][17]
Software Update	D3-SU	T1195.002	Moving to Orion 2020.2.1 HF 2	[99][19]
Restore Software	D3-RS	T1195.002	Rebuilding affected servers	[99][12]
Asset Vulnerability Enumeration	D3-AVE	T1195.002	Version checks against the advisory	[99][17]

Countermeasure	Id	Library mapping to this study's techniques	Guidance in the record it matches	Source
DNS Traffic Analysis	D3-DNSTA	T1071.004, T1568	Hunting avsvmcloud[.]com subdomains and CNAME answers	[99][6][12]
DNS Denylisting	D3-DNSDL	T1071.004, T1568	Blocking the C2 domain	[99][12]
Forward Resolution Domain Denylisting	D3-FRDDL	T1071.004, T1568	Denying resolution of the DGA domain	[99][12]
Outbound Traffic Filtering	D3-OTF	T1071.004, T1568	Restricting management-server egress (Inferred pairing)	[99]
Credential Rotation	D3-CRO	T1606 (parent; the library has no T1606.002 row), T1098.001, T1550.001, T1539, T1110.003	Rolling the token-signing certificate twice; krbtgt reset twice	[99][91][12]
Credential Revocation	D3-CR	T1606, T1098.001, T1550.001, T1539, T1110.003	Removing added service-principal credentials	[99][91]
Reissue Credential	D3-RIC	T1606, T1098.001, T1550.001, T1539, T1110.003	Reissuing credentials after rebuild	[99][12]
Authentication Cache Invalidation	D3-ANCI	T1606, T1098.001, T1550.001, T1539, T1110.003	Revoking forged sessions and tokens	[99][24]
Multi-factor Authentication	D3-MFA	T1606, T1110.003, T1539	Note: Golden SAML and the duo-sid forgery bypassed MFA, so MFA alone does not counter them	[99][45][10]
Token Binding	D3-TB	T1550.001	Limits reuse of stolen application tokens (Inferred pairing)	[99]
User Geolocation Logon Pattern Analysis	D3-UGLPA	T1071.004, T1568, T1098.001, T1550.001, T1110.003	FireEye's impossible-travel and in-country VPS hunt	[99][6]
System Configuration Permissions	D3-SCP	T1546.012	Restricting who can set IFEO debugger values (Inferred pairing)	[99][11]

The library has no D3FEND rows for T1553 or T1553.002, T1552.004, T1484.002 or T1606.002 (Confirmed [99]), so the identity-provider protections that matter most here, protecting the AD FS signing key and alerting on federation changes, have no D3FEND binding in the library today (Inferred).

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, navigator/library-layers/solarwinds-sunburst-2019-2021.json, listed on the Navigator layers page. It is pinned to ATT&CK v20 (navigator 4.9, layer format 4.5) and holds the 112 techniques of the table above as 139 technique-tactic entries, each technique shown under every tactic in its library technique profile. Scores mark membership only. Each entry's comment names the source numbers of this study's Sources table. The layer passes `scripts/validate_navigator.py`.

Cross-cutting themes

- **Trust is the attack surface.** Every hop exploited something defenders were told to trust: a vendor's signed update, a monitoring server's broad access, an identity provider's signing key, a cloud reseller's delegated rights (Confirmed [6][22][66]; Inferred for the pattern). See Supply Chain Security and the XZ Utils study for the open-source version of the same problem.
- **Patience is a technique.** A test run months ahead, two weeks of dormancy, build failures avoided on purpose and the implant removed once its job was done (Confirmed [9][6][7][13]). Detection that depends on noise will miss operators who budget for quiet (Inferred).
- **Identity is the real perimeter.** The cloud follow-on reached mail through forged tokens and added application credentials (Confirmed [22][23]). Hybrid identity puts the cloud's front door on an on-premises server (Inferred from [27], which advises caution with hybrid identity). See Identity Security and Active Directory Attacks.
- **Disclosure came from a victim, not a control.** FireEye found it while investigating its own breach (Confirmed [45][47]); a federal agency allegedly saw Orion contacting unknown sites after a May 2020 install and notified SolarWinds in June 2020 (Confirmed as an allegation [40]). Operating from inside the United States limited intelligence visibility (Confirmed [53]).
- **Attribution has a vocabulary.** "Nation-state", "likely Russian", "highly likely", "high confidence" and "sufficient evidence" are different claims made months apart (Confirmed [31][52][56][54][77]). See Threat Actors.
- **Policy moved faster than review.** The order, the SBOM elements, the SSDF and attestation all followed; the dedicated review of this incident did not (Confirmed [59][97][87][98][93]; Reported [94]).

What is overstated and what is understated

- **Overstated: 18,000 victims.** Fewer than 18,000 customers may have installed the update; follow-on compromise reached nine agencies and about 100 companies (Confirmed [14][53]). The installed base is an exposure count, not a victim count.
- **Overstated: Golden SAML as the whole story.** Microsoft saw forged SAML tokens in about 15 percent of its cases, and only after elevated access (Confirmed [45]).
- **Overstated: "SolarWinds123" as the cause.** The password was raised at a hearing (Confirmed [46]); no opened source shows it was the initial vector (Inferred).
- **Understated: the non-Orion victims.** Password spraying, external remote services, an Exchange exploit and an MFA-integration secret all opened doors without any supply-chain trick (Confirmed [12][10]).
- **Understated: the long timeline.** Access is alleged from January 2019 and the actor's 2021 campaigns continued against new trusted channels (Confirmed as an allegation [40]; Confirmed [65][67]).
- **Understated: the identity provider as a crown jewel.** Neither the library's D3FEND data nor most patch-centric programs treat the AD FS signing key as an asset to defend in its own right (Confirmed [99]; Inferred for the program point).

Sources

All sources were opened on 3 November 2026. "Primary" means the organization that published the fact; grades apply to the source as used here.

#	Source	URL	Opened	Grade
1	MITRE ATT&CK, campaign C0024 SolarWinds Compromise, v1.1	attack.mitre.org/campaigns/C0024	2026-11-03	Confirmed
2	MITRE ATT&CK, software S0559 SUNBURST, v2.5	attack.mitre.org/software/S0559	2026-11-03	Confirmed
3	MITRE ATT&CK, software S0560 TEARDROP	attack.mitre.org/software/S0560	2026-11-03	Confirmed
4	MITRE ATT&CK, software S0562 SUNSPOT, v1.2	attack.mitre.org/software/S0562	2026-11-03	Confirmed
5	MITRE ATT&CK, software S0565 Raindrop, v1.3	attack.mitre.org/software/S0565	2026-11-03	Confirmed
6	Mandiant (then FireEye), SUNBURST backdoor report, 13 Dec 2020	cloud.google.com/blog/.../sunburst-backdoor	2026-11-03	Confirmed
7	CrowdStrike, SUNSPOT technical analysis, 11 Jan 2021	crowdstrike.com/blog/sunspot-malware-technical-analysis	2026-11-03	Confirmed
8	Symantec, Raindrop, 18 Jan 2021	security.com/threat-intelligence/solarwinds-raindrop-malware	2026-11-03	Confirmed
9	SolarWinds, New findings from our investigation of SUNBURST, 11 Jan 2021	solarwinds.com/blog/new-findings-from-our-investigation-of-sunburst	2026-11-03	Confirmed
10	Volexity, Dark Halo and the SolarWinds compromise, 14 Dec 2020	volexity.com/blog/2020/12/14/...	2026-11-03	Confirmed
11	Microsoft, Solorigate second-stage activation deep dive, 20 Jan 2021	microsoft.com/en-us/security/blog/2021/01/20/...	2026-11-03	Confirmed
12	CISA AA20-352A, released 17 Dec 2020, revised 15 Apr 2021	cisa.gov/.../aa20-352a	2026-11-03	Confirmed
13	SolarWinds, timeline graphic	solarwinds.com/.../TimelineGraphic8.jpg	2026-11-03	Confirmed
14	SolarWinds, Form 8-K, 14 Dec 2020	`https://www.sec.gov/Archives/edgar/data/1739942/000162828020017451/swi-20201214.htm`	2026-11-03	Confirmed
15	SolarWinds, Form 8-K, 11 Jan 2021	`https://www.sec.gov/Archives/edgar/data/1739942/000173994221000015/swi-20210111.htm`	2026-11-03	Confirmed
16	SolarWinds, Form 10-K, filed 1 Mar 2021	`https://www.sec.gov/Archives/edgar/data/1739942/000173994221000043/swi-20201231.htm`	2026-11-03	Confirmed
17	SolarWinds, security advisory	solarwinds.com/sa-overview/securityadvisory	2026-11-03	Confirmed
18	SolarWinds, security advisory FAQ	solarwinds.com/sa-overview/securityadvisory/faq	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
19	SolarWinds, update on security vulnerability, 17 Dec 2020	solarwinds.com/blog/solarwinds-update-on-security-vulnerability	2026-11-03	Confirmed
20	Microsoft, Analyzing Solorigate, the compromised DLL, 18 Dec 2020	microsoft.com/en-us/security/blog/2020/12/18/...	2026-11-03	Confirmed
21	Mandiant, SUNBURST additional technical details, 24 Dec 2020	cloud.google.com/blog/.../sunburst-additional-technical-details	2026-11-03	Confirmed
22	Microsoft, Using Microsoft 365 Defender against Solorigate, 28 Dec 2020	microsoft.com/en-us/security/blog/2020/12/28/...	2026-11-03	Confirmed
23	Mandiant, Remediation and hardening strategies for Microsoft 365 against UNC2452, 19 Jan 2021 (updated 28 Oct 2021)	cloud.google.com/blog/.../unc2452	2026-11-03	Confirmed
24	CISA AA21-008A, revised 15 Apr 2021	cisa.gov/.../aa21-008a	2026-11-03	Confirmed
25	CISA Emergency Directive 21-01	cisa.gov/.../ed-21-01	2026-11-03	Confirmed
26	Microsoft, GoldMax, GoldFinder and Sibot, 4 Mar 2021	microsoft.com/en-us/security/blog/2021/03/04/...	2026-11-03	Confirmed
27	MSRC, Microsoft internal Solorigate investigation, final update, 18 Feb 2021	microsoft.com/en-us/msrc/blog/2021/02/...	2026-11-03	Confirmed
28	MSRC, Microsoft internal Solorigate investigation update, 31 Dec 2020	microsoft.com/en-us/msrc/blog/2020/12/...	2026-11-03	Confirmed
29	MSRC, Customer guidance on recent nation-state cyber attacks, 14 Dec 2020	microsoft.com/en-us/msrc/blog/2020/12/...	2026-11-03	Confirmed
30	Microsoft On the Issues, protecting customers, 13 Dec 2020	blogs.microsoft.com/on-the-issues/2020/12/13/...	2026-11-03	Confirmed
31	Microsoft On the Issues, Brad Smith, 17 Dec 2020	blogs.microsoft.com/on-the-issues/2020/12/17/...	2026-11-03	Confirmed
32	CISA Known Exploited Vulnerabilities catalog, JSON feed	cisa.gov/.../known_exploited_vulnerabilities.json	2026-11-03	Confirmed
33	CVE record CVE-2020-10148	cveawg.mitre.org/api/cve/CVE-2020-10148	2026-11-03	Confirmed
34	CVE record CVE-2020-0688	cveawg.mitre.org/api/cve/CVE-2020-0688	2026-11-03	Confirmed
35	MITRE CAPEC-673	capec.mitre.org/data/definitions/673.html	2026-11-03	Confirmed
36	MITRE CAPEC-511	capec.mitre.org/data/definitions/511.html	2026-11-03	Confirmed
37	MITRE CAPEC-678	capec.mitre.org/data/definitions/678.html	2026-11-03	Confirmed
38	MITRE D3FEND, offensive technique T1195.002	d3fend.mitre.org/offensive-technique/attack/T1195.002	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
39	TeamStarWolf library, `data/attack/` (ATT&CK v20.0 data, superseded_by.jsonl, CAPEC edges, technique profiles) and the generated `mitre/` pages, main e85b559	github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-03	Confirmed
40	SEC v. SolarWinds and its CISO, complaint, 30 Oct 2023	`https://www.sec.gov/files/litigation/complaints/2023/comp-pr2023-227.pdf`	2026-11-03	Confirmed (allegations)
41	SEC press release 2023-227, 30 Oct 2023	`https://www.sec.gov/newsroom/press-releases/2023-227`	2026-11-03	Confirmed
42	SEC litigation release LR-26423	`https://www.sec.gov/enforcement-litigation/litigation-releases/lr-26423`	2026-11-03	Confirmed
43	SEC, joint stipulation of dismissal, filed 20 Nov 2025	`https://www.sec.gov/files/litigation/complaints/2025/comp26423.pdf`	2026-11-03	Confirmed
44	GAO-22-104746, 13 Jan 2022	`https://www.gao.gov/products/gao-22-104746`	2026-11-03	Confirmed
45	Senate Select Committee on Intelligence, open hearing, 23 Feb 2021 (transcript)	govinfo.gov/.../CHRG-117shrg45485	2026-11-03	Confirmed
46	House Oversight and Homeland Security joint hearing, 26 Feb 2021 (transcript)	govinfo.gov/.../CHRG-117hhrg43755	2026-11-03	Confirmed
47	FireEye, Form 8-K, 8 Dec 2020	`https://www.sec.gov/Archives/edgar/data/1370880/000137088020000037/feye-20201208.htm`	2026-11-03	Confirmed
48	FireEye, unauthorized access of red-team tools, 8 Dec 2020	cloud.google.com/blog/.../unauthorized-access-of-fireeye-red-team-tools	2026-11-03	Confirmed
49	Mandiant, red_team_tool_countermeasures, CVE list	github.com/mandiant/red_team_tool_countermeasures	2026-11-03	Confirmed
50	Mandiant, sunburst_countermeasures	github.com/mandiant/sunburst_countermeasures	2026-11-03	Confirmed
51	Lawfare, reproduction of the FBI, CISA and ODNI joint statement of 16 Dec 2020 (CISA original returned 404)	lawfaremedia.org/article/...	2026-11-03	Reported
52	FBI, CISA, ODNI and NSA joint statement, 5 Jan 2021	cisa.gov/news-events/news/joint-statement-...-0	2026-11-03	Confirmed
53	White House, press briefing with Anne Neuberger, 17 Feb 2021	bidenwhitehouse.archives.gov/.../2021/02/17/...	2026-11-03	Confirmed
54	White House, fact sheet on imposing costs on the Russian government, 15 Apr 2021	bidenwhitehouse.archives.gov/.../2021/04/15/...	2026-11-03	Confirmed
55	US Treasury, press release jy0127, 15 Apr 2021	home.treasury.gov/news/press-releases/jy0127	2026-11-03	Confirmed
56	UK NCSC, UK and US call out Russia for SolarWinds compromise, 15 Apr 2021	ncsc.gov.uk/news/uk-and-us-call-out-russia-for-solarwinds-compromise	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
57	CISA, NSA-CISA-FBI joint advisory on SVR targeting, 15 Apr 2021 (NSA page returned 403)	cisa.gov/news-events/alerts/2021/04/15/...	2026-11-03	Confirmed
58	CISA AA21-116A, Russian SVR cyber operations, 26 Apr 2021	cisa.gov/.../aa21-116a	2026-11-03	Confirmed
59	Executive Order 14028, Daily Compilation of Presidential Documents	govinfo.gov/app/details/DCPD-202100401	2026-11-03	Confirmed
60	White House, Executive Order on improving the nation's cybersecurity, 12 May 2021	bidenwhitehouse.archives.gov/.../2021/05/12/...	2026-11-03	Confirmed
61	Microsoft, new email-based attack from NOBELIUM, 27 May 2021	microsoft.com/en-us/security/blog/2021/05/27/...	2026-11-03	Confirmed
62	Microsoft, NOBELIUM's early-stage toolset, 28 May 2021	microsoft.com/en-us/security/blog/2021/05/28/...	2026-11-03	Confirmed
63	MSRC, new NOBELIUM activity, 25 Jun 2021	microsoft.com/en-us/msrc/blog/2021/06/new-nobelium-activity	2026-11-03	Confirmed
64	Microsoft, FoggyWeb, 27 Sep 2021	microsoft.com/en-us/security/blog/2021/09/27/...	2026-11-03	Confirmed
65	Microsoft On the Issues, new activity from NOBELIUM, 24 Oct 2021	blogs.microsoft.com/on-the-issues/2021/10/24/...	2026-11-03	Confirmed
66	MSTIC, NOBELIUM targeting delegated administrative privileges, 25 Oct 2021	microsoft.com/en-us/security/blog/2021/10/25/...	2026-11-03	Confirmed
67	Mandiant, Russian targeting of government and business, 6 Dec 2021	cloud.google.com/blog/.../russian-targeting-gov-business	2026-11-03	Confirmed
68	Mandiant, SUNSHUTTLE second-stage backdoor, 4 Mar 2021	cloud.google.com/blog/.../sunshuttle	2026-11-03	Confirmed
69	Palo Alto Networks Unit 42, SolarStorm supply-chain attack timeline, 23 Dec 2020	unit42.paloaltonetworks.com/solarstorm-supply-chain-attack-timeline	2026-11-03	Confirmed
70	Kaspersky Securelist, SUNBURST backdoor and Kazuar, 11 Jan 2021	securelist.com/sunburst-backdoor-kazuar/99981	2026-11-03	Confirmed
71	UK FCDO, Foreign Office summons Russian ambassador, 15 Apr 2021	gov.uk/government/news/russia-foreign-office-summons-russian-ambassador	2026-11-03	Confirmed
72	NATO, North Atlantic Council statement, 15 Apr 2021	nato.int/cps/en/natohq/news_183168.htm	2026-11-03	Confirmed
73	UK NCSC, APT29 targets COVID-19 vaccine development, 16 Jul 2020	ncsc.gov.uk/news/advisory-apt29-targets-covid-19-vaccine-development	2026-11-03	Confirmed
74	RFE/RL, SVR director denies SolarWinds responsibility (BBC interview not opened)	rferl.org/amp/russia-svr-denies-solarwinds/31260606.html	2026-11-03	Reported
75	Microsoft, shift to a new threat actor naming taxonomy, 18 Apr 2023	microsoft.com/en-us/security/blog/2023/04/18/...	2026-11-03	Confirmed
76	Microsoft Learn, threat actor naming	learn.microsoft.com/en-us/unified-secops/microsoft-threat-actor-naming	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
77	Mandiant, UNC2452 merged into APT29, 27 Apr 2022	cloud.google.com/blog/.../unc2452-merged-into-apt29	2026-11-03	Confirmed
78	CrowdStrike, observations from the StellarParticle campaign, 27 Jan 2022	crowdstrike.com/en-us/blog/observations-from-the-stellarparticle-campaign	2026-11-03	Confirmed
79	CISA AR21-112A, SUPERNOVA, 22 Apr 2021	cisa.gov/news-events/analysis-reports/ar21-112a	2026-11-03	Confirmed
80	Secureworks CTU, SUPERNOVA web shell deployment linked to SPIRAL (now hosted by Sophos; no publication date on the page)	`https://www.sophos.com/en-us/blog/supernova-web-shell-deployment-linked-to-spiral-threat-group`	2026-11-03	Confirmed
81	MITRE ATT&CK, group G0016 APT29, v6.2	attack.mitre.org/groups/G0016	2026-11-03	Confirmed
82	MITRE ATT&CK, legacy group id G0118 (redirects to G0016)	attack.mitre.org/groups/G0118	2026-11-03	Confirmed
83	MITRE ATT&CK, T1195.002 Compromise Software Supply Chain	attack.mitre.org/techniques/T1195/002	2026-11-03	Confirmed
84	Cybersecurity Dive, SUNSPOT coverage reproducing SolarWinds' timeline	`https://cybersecuritydive.com/news/sunspot-malware-sunburst-crowdstrike-solarwinds/593215`	2026-11-03	Reported
85	SolarWinds, setting the new standard in secure software development, 10 Mar 2022	solarwinds.com/blog/setting-the-new-standard-in-secure-software-development	2026-11-03	Confirmed
86	SolarWinds, next-generation build system aligns with NIST SSDF, 18 Jul 2023	solarwinds.com/company/newsroom/press-releases/...	2026-11-03	Confirmed (self-assessment)
87	NIST SP 800-218, Secure Software Development Framework v1.1, Feb 2022	nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-218.pdf	2026-11-03	Confirmed
88	CISA and NIST, Defending Against Software Supply Chain Attacks, Apr 2021	cisa.gov/.../defending_against_software_supply_chain_attacks_508_1.pdf	2026-11-03	Confirmed
89	KrebsOnSecurity, malicious domain turned into a kill switch, Dec 2020	krebsonsecurity.com/2020/12/malicious-domain-in-solarwinds-hack-turned-into-killswitch	2026-11-03	Reported
90	CISA, NSA releases advisory on detecting abuse of authentication mechanisms, 17 Dec 2020 (NSA PDF returned 403)	cisa.gov/news-events/alerts/2020/12/17/...	2026-11-03	Confirmed
91	Microsoft, advice for incident responders on recovery from systemic identity compromises, 21 Dec 2020	microsoft.com/en-us/security/blog/2020/12/21/...	2026-11-03	Confirmed
92	CyberArk, shimit (Golden SAML), repository created 7 Nov 2017	github.com/cyberark/shimit	2026-11-03	Demonstrated
93	Cyber Safety Review Board, report on Log4j, 11 Jul 2022	cisa.gov/.../CSRB-Report-on-Log4-July-11-2022_508.pdf	2026-11-03	Confirmed

#	Source	URL	Opened	Grade
94	ProPublica, the Cyber Safety Review Board never investigated SolarWinds, 8 Jul 2024	propublica.org/article/cyber-safety-board-never-investigated-solarwinds-breach-microsoft	2026-11-03	Reported
95	Nextgov, DHS cyber review board memberships ended, Jan 2025	nextgov.com/cybersecurity/2025/01/...	2026-11-03	Reported
96	Atlantic Council, Broken Trust, Mar 2021	atlanticcouncil.org/.../BROKEN-TRUST.pdf	2026-11-03	Confirmed
97	NTIA, minimum elements for a software bill of materials, 12 Jul 2021	ntia.gov/report/2021/minimum-elements-software-bill-materials-sbom	2026-11-03	Confirmed
98	OMB M-22-18, 14 Sep 2022	bidenwhitehouse.archives.gov/wp-content/uploads/2022/09/M-22-18.pdf	2026-11-03	Confirmed
99	TeamStarWolf library, `data/attack/technique_to_d3fend.jsonl`	github.com/TeamStarWolf/TeamStarWolf/blob/main/data/attack/technique_to_d3fend.jsonl	2026-11-03	Confirmed

Related references

- Threat Actors, Malware Families, Notable Incidents, CVE Reference
- Supply Chain Security, Supply Chain Security Reference, Identity Security Reference, Active Directory Attacks, Cloud Attack Reference
- Vulnerability Management Reference, Detection Rules Reference
- CWE Reference, CAPEC Reference, D3FEND Reference
- Case studies: XZ Utils Backdoor 2024
- Groups: G0016 APT29, G0010 Turla
- Campaigns: C0024 SolarWinds Compromise, C0023 Operation Ghost
- Software: S0559 SUNBURST, S0562 SUNSPOT, S0560 TEARDROP, S0565 Raindrop, S0154 Cobalt Strike, S0552 AdFind, S0002 Mimikatz, S0588 GoldMax, S0597 GoldFinder, S0589 Sibot, S0682 TrailBlazer, S0661 FoggyWeb
- Techniques: T1195.002 Compromise Software Supply Chain, T1565.001 Stored Data Manipulation, T1553.002 Code Signing, T1071.004 DNS, T1606.002 SAML Tokens, T1552.004 Private Keys, T1484.002 Trust Modification, T1098.001 Additional Cloud Credentials
- CAPEC: CAPEC-678, CAPEC-673, CAPEC-511, CAPEC-206
- Navigator layers, including this study's layer, solarwinds-sunburst-2019-2021.json